

IT Security 2

Unit 4 – Admin Accounts

Instructor: Brian Krause

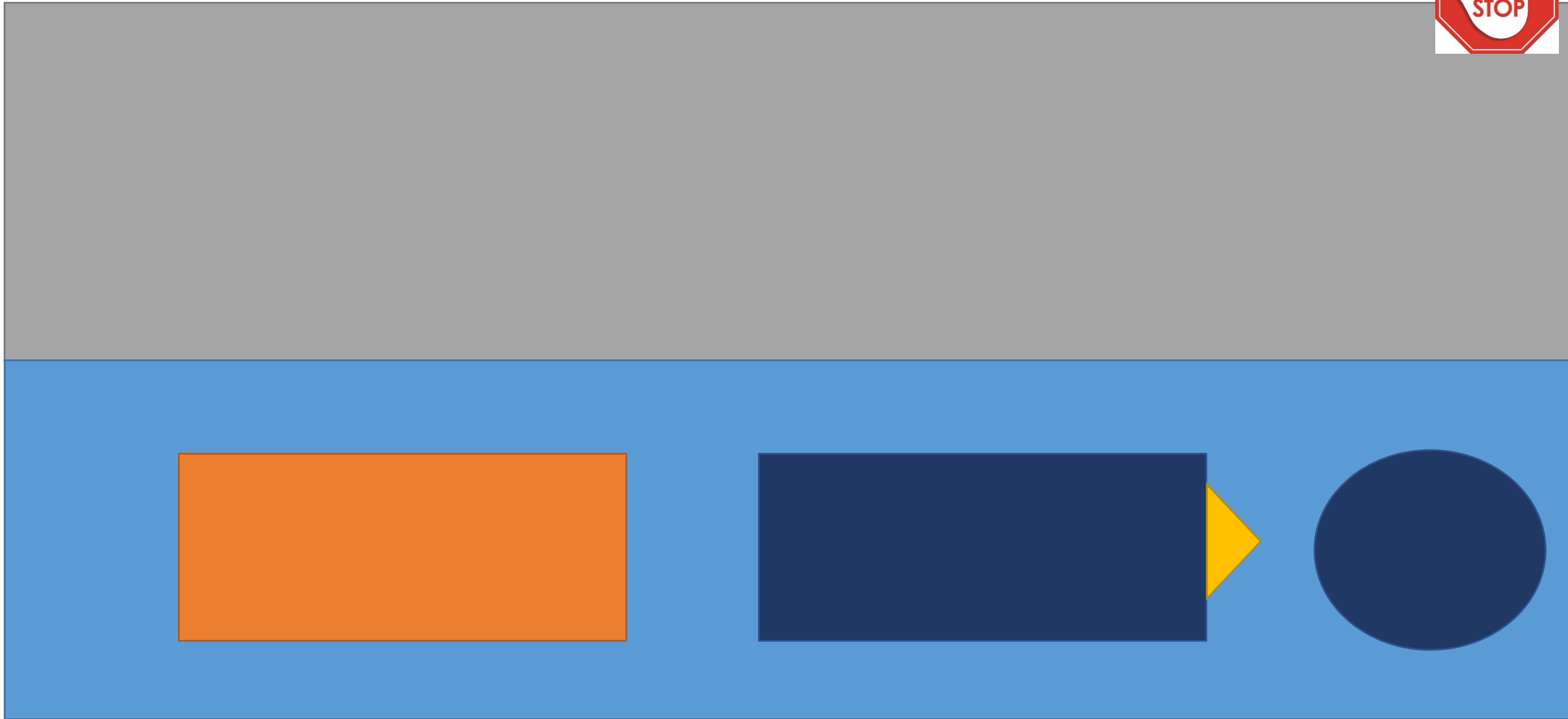
Announcements

- Class Questions Results
- IT Club Meeting this Wednesday at noon!
- Cool source of news: PAN Unit 42 <https://unit42.paloaltonetworks.com/>

Admin Account Overview

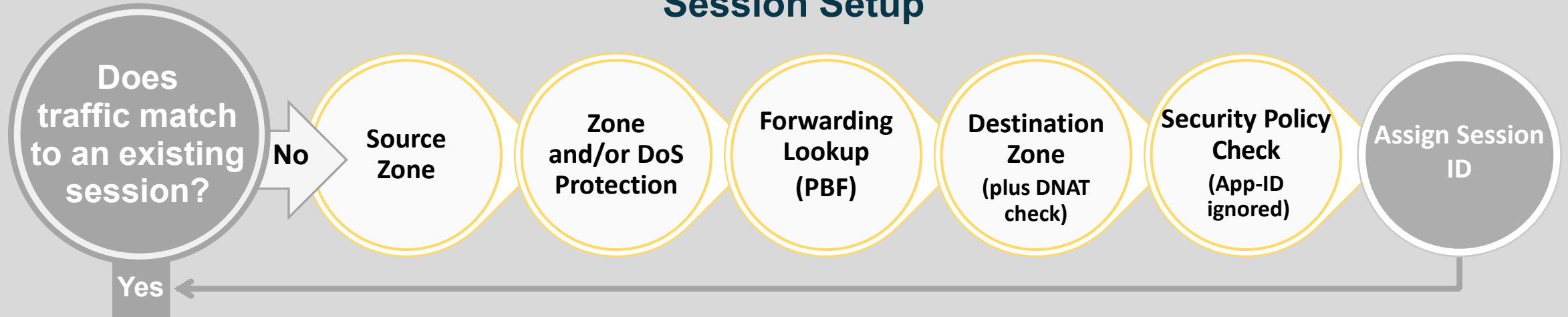
Some slides were adapted from Palo-Alto for use in this class. Content is a mesh between vendor provided information and instructor comments.

Flow Logic of the Next-Generation Firewall

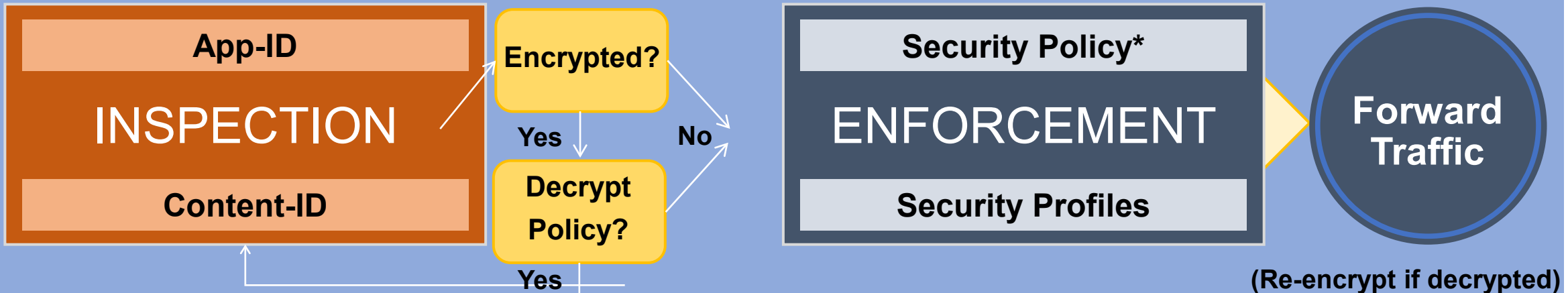


Flow Logic of the Next-Generation Firewall

Session Setup



Inspection and Enforcement



* Policy check relies on pre-NAT IP addresses

MANAGING FIREWALL ADMINISTRATOR ACCOUNTS



*TREAT YOUR ACCOUNT LIKE A
TOOTHBRUSH: DON'T LET ANYONE
ELSE USE IT*

- Firewall authentication and authorization
- Create a local firewall administrator account
- Create a non-local firewall administrator account
- Create a firewall administrator account for non-interactive login

EDU-210 Version B
PAN-OS® 11.0



Learning Objectives

After you complete this module, you should be able to:

- Describe the firewall authentication and authorization process and firewall components
- Create a local firewall administrator account
- Create a non-local firewall administrator account
- Create a firewall account that supports non-interactive login



Treat Administrator Accounts Like a Toothbrush

- Each administrator account is personal and should **never be shared**.
- **Best Practice:**
 - Use strong, unique passwords.
 - Rotate credentials regularly.
 - Assign individual accounts instead of group/shared accounts to ensure **accountability**.
- **Why it matters:** Shared accounts make it impossible to trace changes or security incidents back to a specific user.

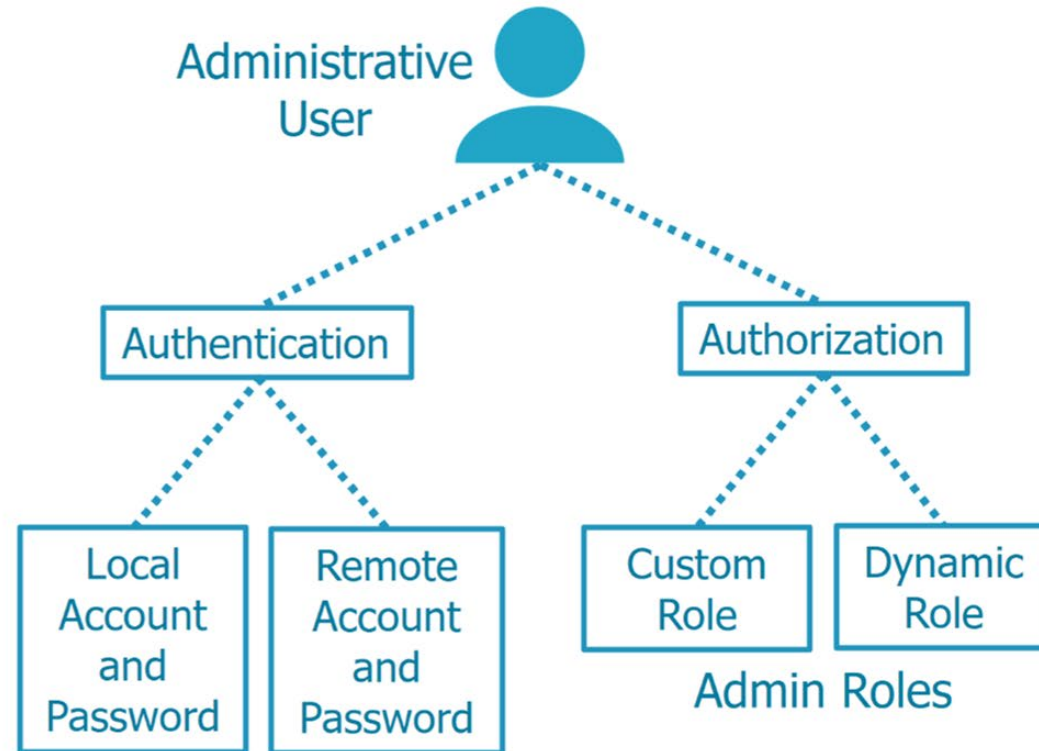


Firewall authentication and authorization

Administrator Accounts and Roles

- The firewall can authenticate locally or remotely defined administrators.
- Each administrative account is assigned a role with specific privileges.
- Administrator actions are logged in the Configuration and System logs:
 - **Monitor > Logs**

For a Tech Doc about this topic, log into Live and search for "Plan Your Authentication Deployment."



Firewall Authentication & Authorization Overview

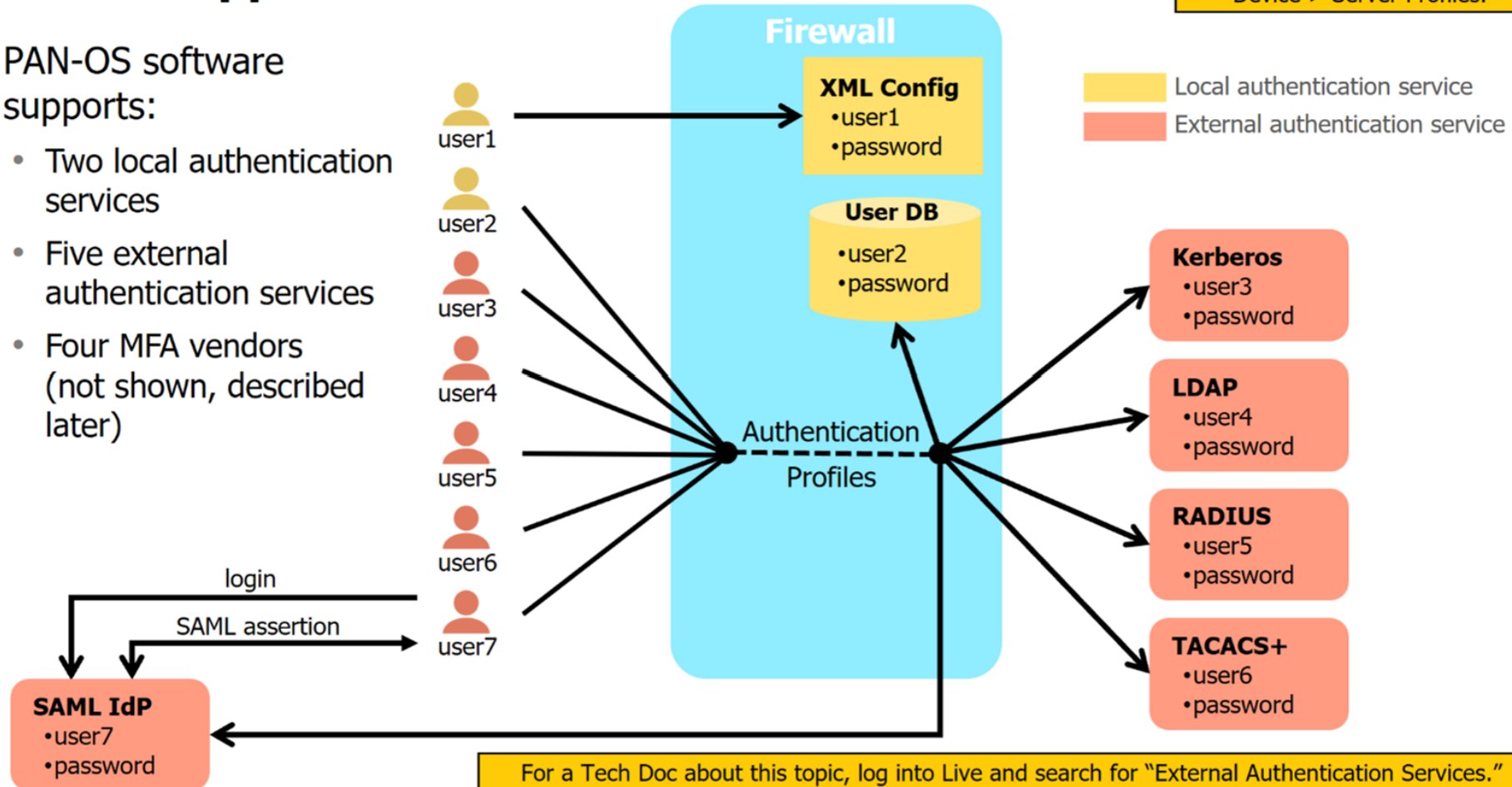
- **Authentication:** Verifies user identity (username, password, certificate, MFA).
- **Authorization:** Determines what actions an authenticated user can perform.
- **Logging:** All administrative actions are recorded in **Configuration and System logs**.

Extra Note: This separation follows the **AAA model (Authentication, Authorization, Accounting)** used in network security.

PAN-OS Supported Authentication Services

For a Tech Doc about this topic, log into Live and search for "Device > Server Profiles."

- PAN-OS software supports:
 - Two local authentication services
 - Five external authentication services
 - Four MFA vendors (not shown, described later)

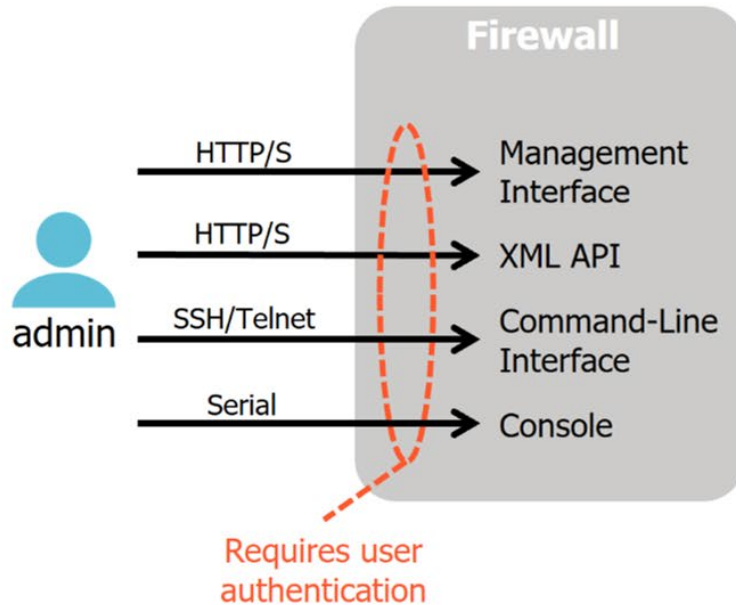


For a Tech Doc about this topic, log into Live and search for "External Authentication Services."

When are Users Authenticated?

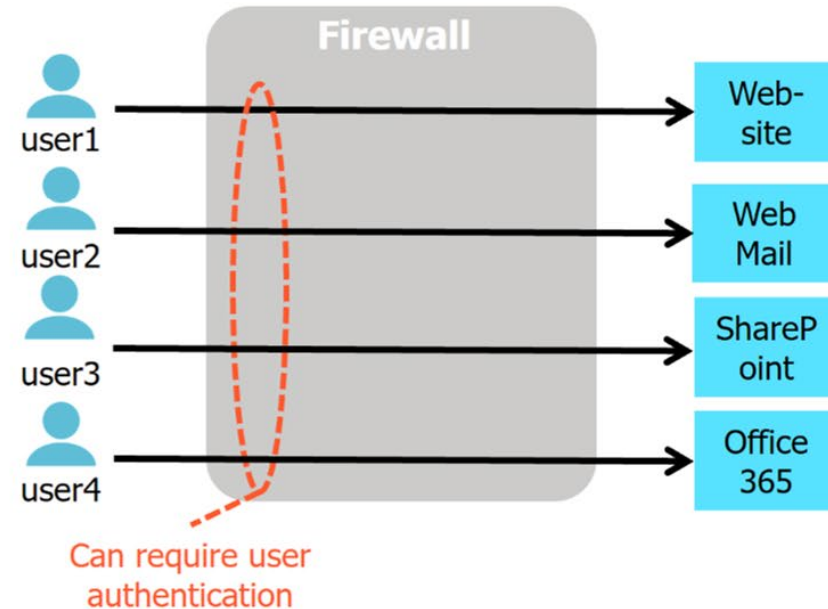
Users Connecting to Firewall Services

"connecting *to* the firewall"



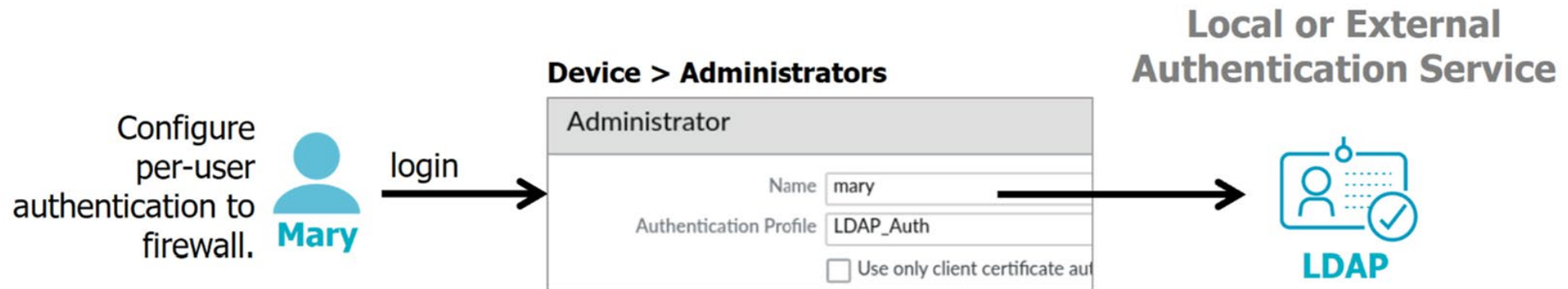
Users Connecting to Network Resources

"connecting *through* the firewall"



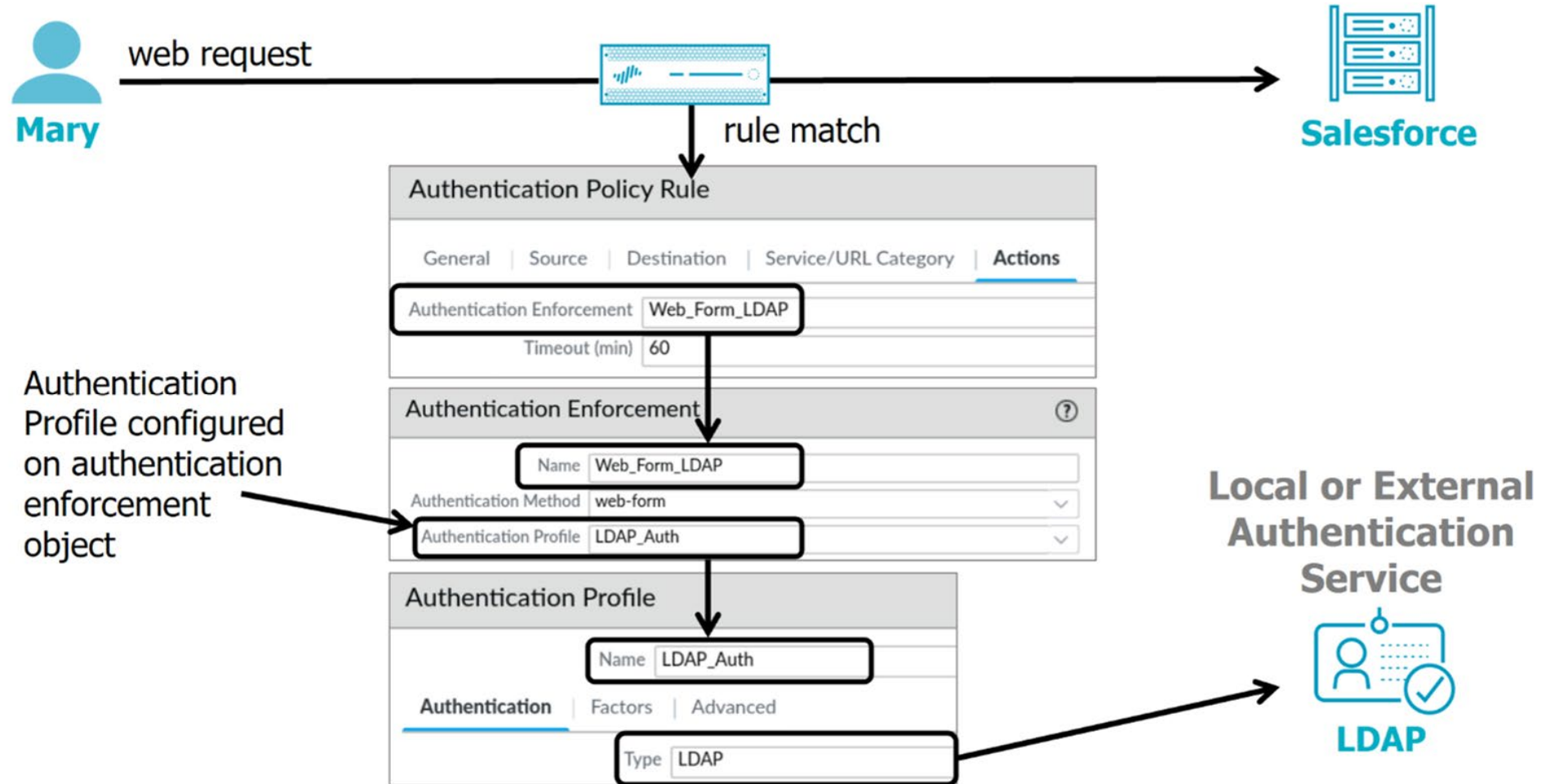
Configure Authentication “to” the Firewall

The method used to authenticate users *to* the firewall depends on where you configure the user’s Authentication Profile.



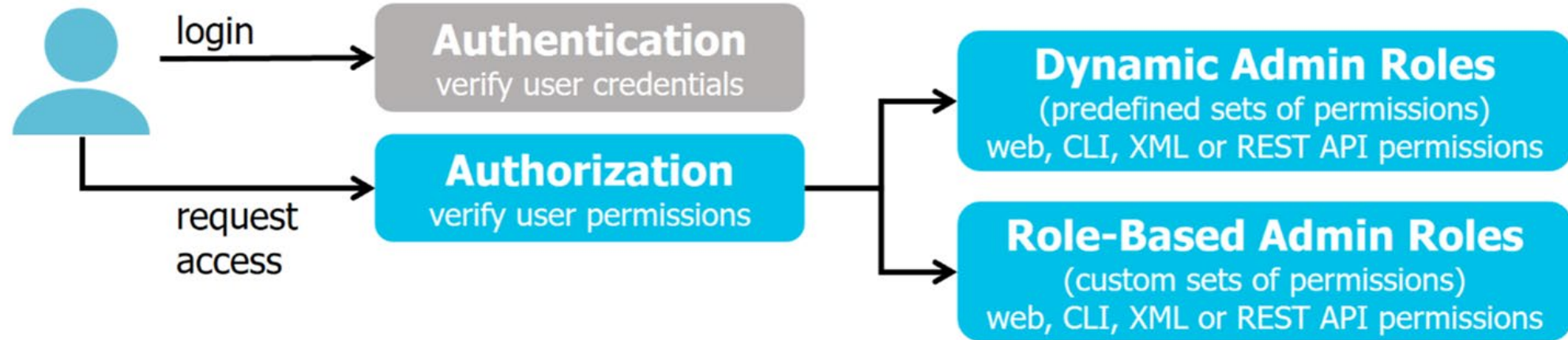
Supported only for RADIUS, TACACS+, and SAML

Configure Authentication “through” the Firewall



User Authorization "to" and "Through" the Firewall

Authorization to manage the firewall controlled by Admin Role Profiles:



Authorization to access network resources *through* the firewall controlled by Security policy:

	NAME	TYPE	Source				Destination			APPLICATION	SERVICE	ACTION
			ZONE	ADDRESS	USER	DEVICE	ZONE	ADDRESS	DEVICE			
1	Marketing-FB	universal	Users_Net	any	Marketing	any	Internet	any	any	facebook	application-default	Allow

↑ Must configure User-ID ↑

Summary: When Are Users Authenticated?

- **To the Firewall (Admins):**
 - Management Interface
 - CLI
 - Web GUI
 - API
- **Through the Firewall (Users):**
 - Access to webmail, Office 365, SharePoint, etc.

Think of it as:

“To” = accessing the firewall itself

“Through” = traffic passing through the firewall

Administrator Accounts and Roles

- **Recap:**

- **Local Accounts:** Credentials stored on the firewall.

Remote Accounts: Credentials stored in external systems (LDAP, RADIUS, TACACS+, SAML, Kerberos).

- **Roles:**

- **Dynamic Admin Roles** → Predefined sets of permissions that update with new PAN-OS versions.
 - **Custom Role-Based Roles** → Admin-defined roles with granular permissions.

Dynamic Admin Roles

Device > Administrators > Add

Administrator ?

Name

Authentication Profile

☐ Use only client certificate authentication (Web)

Password

Confirm Password

☐ Use Public Key Authentication (SSH)

Administrator Type ☒ Dynamic ☐ Role Based

Password Profile

Superuser

Superuser (read-only)

Device administrator

Device administrator (read-only)

Updated automatically when new capabilities are added to the PAN-OS software

Create Custom Role-Based Admin Roles

Device > Admin Roles > Add

Admin Role Profile	
Name	Policy-Admin
Description	Role created for Policy Administrators
Web UI XML API Command Line REST API	
☒ Dashboard ☒ ACC ☒ Monitor ☒ Logs ☒ Traffic ☒ Threat ☒ URL Filtering ☒ WildFire Submissions ☒ Data Filtering ☒ HIP Match ☒ GlobalProtect ☒ IP-Tag ☒ User-ID ☒ Decryption ☒ Tunnel Inspection	
Legend: ☒ Enable ☐ Read Only ☒ Disable	

Admin Role Profile	
Name	Policy-Admin
Description	Role created for Policy Administrators
Web UI XML API Command Line REST API	
☒ Report ☒ Log ☒ Configuration ☒ Operational Requests ☒ Commit ☒ User-ID Agent ☒ IoT Agent ☒ Export ☒ Import	
Legend: ☒ Enable ☐ Read Only ☒ Disable	

Admin Role Profile	
Name	Policy-Admin
Description	Role created for Policy Administrators
Web UI XML API Command Line REST API	
None None superuser superreader deviceadmin deviceviewer	
Legend: ☒ Enable ☐ Read Only ☒ Disable	

Admin Role Profile	
Name	Policy-Admin
Description	Role created for Policy Administrators
Web UI XML API Command Line REST API	
☒ Objects ☒ Addresses ☒ Address Groups ☒ Regions ☒ Dynamic User Groups ☒ Applications ☒ Application Groups ☒ Application Filters ☒ Services ☒ Service Groups ☒ Tags ☒ Devices ☒ GlobalProtect HIP Objects ☒ GlobalProtect HIP Profiles ☒ External Dynamic Lists	
Legend: ☒ Enable ☐ Read Only ☒ Disable	

Creating a Role-Based Role



Create a local firewall administrator account

Create a Local (Non-Database) Administrator Account

Device > Administrators > Add

Administrator ?

Name

Authentication Profile

☐ Use only client certificate authentication (Web)

Password

Confirm Password

☐ Use Public Key Authentication (SSH)

Administrator Type ☒ Dynamic ☐ Role Based

Password Profile

Administrator Type ☐ Dynamic ☒ Role Based

Profile

Password Profile

Superuser

Superuser (read-only)

Device administrator

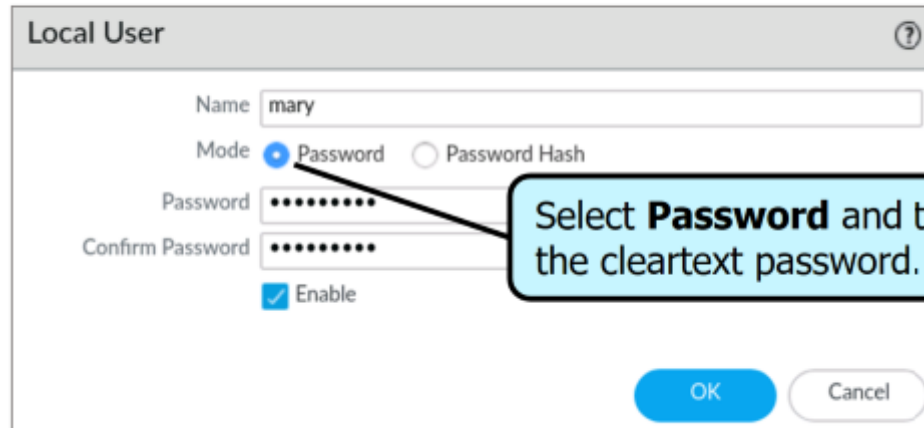
Device administrator (read-only)

New Admin Role Profile

Create a User in the User Database

Create a User in the User Database

Device > Local User Database > Users > Add



The screenshot shows the 'Local User' dialog box. The 'Name' field contains 'mary'. The 'Mode' section has two radio buttons: 'Password' (selected) and 'Password Hash'. The 'Password' field is filled with dots, and the 'Confirm Password' field is also filled with dots. The 'Enable' checkbox is checked. At the bottom are 'OK' and 'Cancel' buttons. A callout box points to the 'Password' radio button.

Local User

Name: mary

Mode: ☒ Password ☐ Password Hash

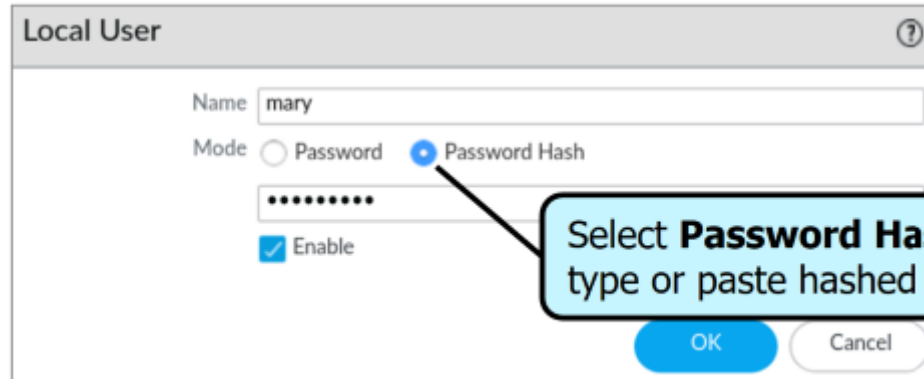
Password:

Confirm Password:

☒ Enable

OK Cancel

Select **Password** and type the cleartext password.



The screenshot shows the 'Local User' dialog box. The 'Name' field contains 'mary'. The 'Mode' section has two radio buttons: 'Password' and 'Password Hash' (selected). The 'Password' field is filled with dots. The 'Enable' checkbox is checked. At the bottom are 'OK' and 'Cancel' buttons. A callout box points to the 'Password Hash' radio button.

Local User

Name: mary

Mode: ☐ Password ☒ Password Hash

.....

☒ Enable

OK Cancel

Select **Password Hash** and type or paste hashed password.

- Users can be created in the local database:
 - Not recommended if an external authentication service is available
- Users can be added as firewall administrators (**Device > Administrators**).
- Users can be used by the firewall to authenticate traffic flowing *through* the firewall.

For a Tech Doc about this topic, log into Live and search for "Device > Local User Database > Users."

Create a Local Database Authentication Profile

Device > Authentication Profile > Add

Authentication Profile

Name LOCAL_Auth

Authentication | Factors | Advanced

Type Local Database

User Domain

Username Modifier %USERINPUT%

Single Sign On

Kerberos Realm

Kerberos Keytab Click "Import" to configure this field X Import

None
Cloud Authentication Service
Local Database
RADIUS
LDAP
TACACS+
SAML
Kerberos

CAUTION: Allows any username with any password

Links a username to the authentication service that authenticates the user's credentials

Authentication Profile: Advanced Tab

Device > Authentication Profile

Authentication Profile

Name LOCAL_Auth

Authentication Factors **Advanced**

Allow List

☐	ALLOW LIST ^
☐	mary
☒	all
	Marketing
	mary

+ Add - Delete

Account Lockout

Failed Attempts 3

Lockout Time (min) 10

Defines users or groups that can be authenticated by this profile

Specify **Account Lockout** settings for failed login attempts.

Create an Administrator Account from a Local Database User

Device > Administrators > Add

Administrator

Name

mary

Authentication Profile

LOCAL_Auth

☐ Use only client certificate authentication (Web)

☐ Use Public Key Authentication (SSH)

Administrator Type

☐ Dynamic ☒ Role Based

Profile

Policy-Admin

Select or create an Authentication Profile (or authentication sequence).

Select or create an Admin Role Profile.



Create a non-local firewall administrator account

Create a Non-Local Administrator Account

Device > Administrators > Add

Administrator ?

Name

Authentication Profile

☐ Use only client certificate authentication

☐ Use Public Key Authentication (SSH)

Administrator Type ☒ Dynamic ☐ Role Based

Super

None
LDAP_Auth
LOCAL_Auth
RADIUS_Auth
New Authentication Profile

Password maintained in external service

Firewall Authentication of Non-Local Passwords

Server Profile:

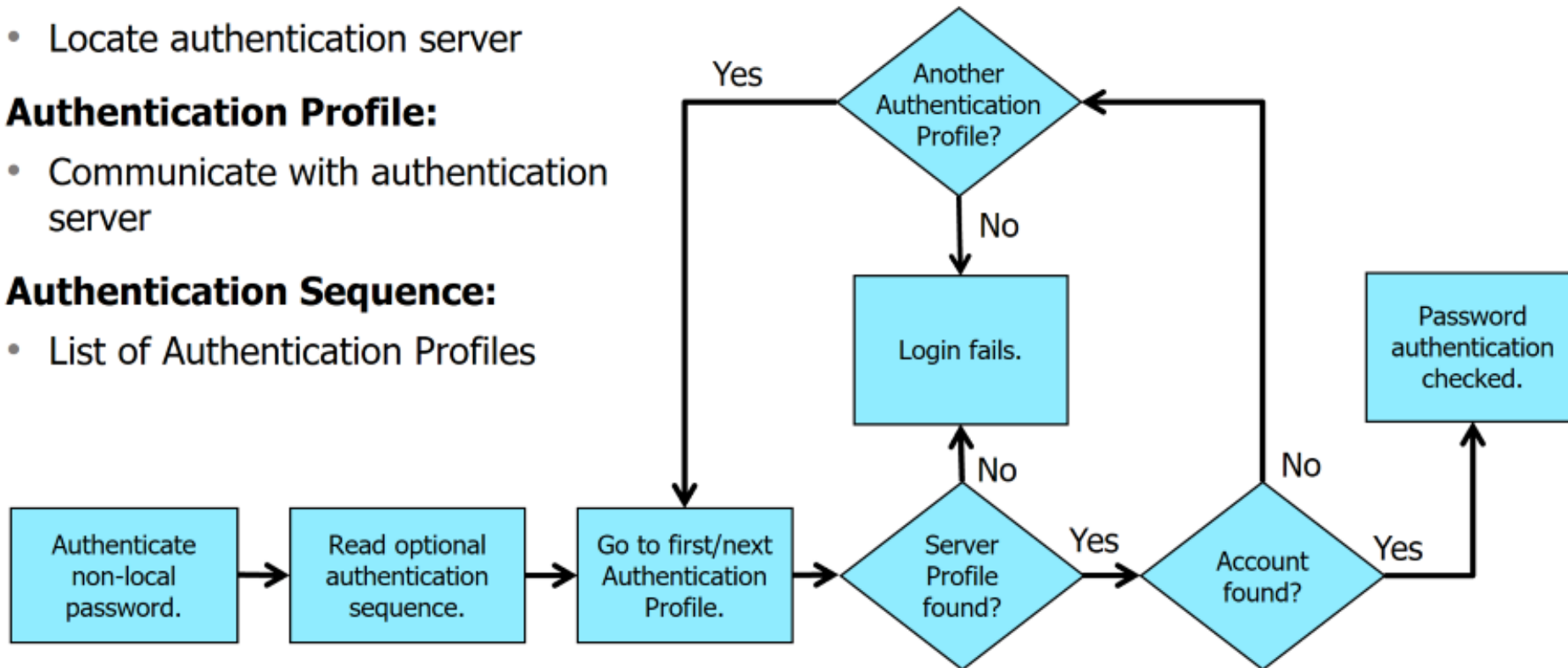
- Locate authentication server

Authentication Profile:

- Communicate with authentication server

Authentication Sequence:

- List of Authentication Profiles



Configure Server Profiles

Device > Server Profiles

PA-VM

DASHBOARD ACC MONITOR POLICIES OBJECTS NETWORK **DEVICE**

Commit

1 item

Server Profiles

- SNMP Trap
- Syslog
- Email
- HTTP
- Netflow
- RADIUS
- TACACS+
- LDAP**
- Kerberos

NAME	LOCATION	SERVERS	OTHERS
LDAP_Server_Profile		Name: LDAP1 LDAP Server: ldap1.lab.local Port: 389	Base: dc=lab,dc=local Bind DN: cn=admin,dc=lab,dc=local

LDAP Server Profile

Profile Name: LDAP_Server_Profile

☐ Administrator Use Only

Server List

NAME	LDAP SERVER	PORT
LDAP1	ldap1.panw.lab	389
LDAP2	ldap2.panw.lab	389

+ Add - Delete

Enter the IP address or FQDN of the LDAP server

Server Settings

Type: other

Base DN: dc=panw,dc=lab

Bind DN: cn=admin,dc=panw,dc=lab

Password:

Confirm Password:

Bind Timeout: 32

Search Timeout: 30

Retry Interval: 60

☐ Require SSL/TLS secured connection

☐ Verify Server Certificate for SSL sessions

For a Tech Doc about this topic,
log into Live and search for
"Device > Server Profiles."

Configure Authentication Profiles

Device > Authentication Profiles

The screenshot shows the Palo Alto VM configuration interface. The left sidebar contains a navigation menu with options like Password Profiles, Administrators, Admin Roles, Authentication Profile (selected), Authentication Sequence, User Identification, Data Redistribution, Device Quarantine, VM Information Sources, Troubleshooting, Certificate Management, Certificates, Certificate Profile, OCSP Responder, SSL/TLS Service Profile, SCEP, SSL Decryption Exclusion, and SSH Service Profile. The main area displays a table of authentication profiles. A callout box points to the 'SERVER PROFILE' column, stating: 'Specifies Server Profile to use for each type of authentication.'

	NAME	LOCATION	Lockout FAILED ATTEMPTS (#)	Lockout LOCKOUT TIME (MIN)	ALLOW LIST	AUTHENTICAT...	SERVER PROFILE	AUTHENTIC... FACTORS	OTHERS	LOCKED USERS
☐	LDAP_Auth			0	all	LDAP	LDAP_Server_Profile		Password Exp Msg: 7 days	none
☐	RADIUS_Auth			0	all	RADIUS	RADIUS_Server_Profile			none
☐	LOCAL_Auth		3	10	mary	Local				none

admin | Logout | Last Login Time: 07/08/2020 17:53:05 | Session Expire Time: 08/08/2020 17:34:06

Configure an Authentication Sequence

Device > Authentication Sequence > Add

PA-VM DASHBOARD ACC MONITOR POLICIES OBJECTS NETWORK **DEVICE** Commit

Search: 1 item

Authentication Sequence

NAME
Two_Auth_Systems

Authentication Sequence Settings

☒ Use domain to determine authentication profile

AUTHENTICATION PROFILES

☐ LDAP_Auth
☐ RADIUS_Auth

Change order of profiles.

Check LDAP first, then RADIUS.

↑ Move Up ↓ Move Down



Create a firewall administrator account for non-interactive login

Administrator Authentication Methods

- Password-based (interactive).
- Certificate-based (non-interactive, for web GUI only).

Best Practice: Use certificates for automation/non-interactive logins (e.g., scripts, monitoring tools). Always combine with role restrictions.

Administrator Authentication Methods

Password Authentication (Interactive)

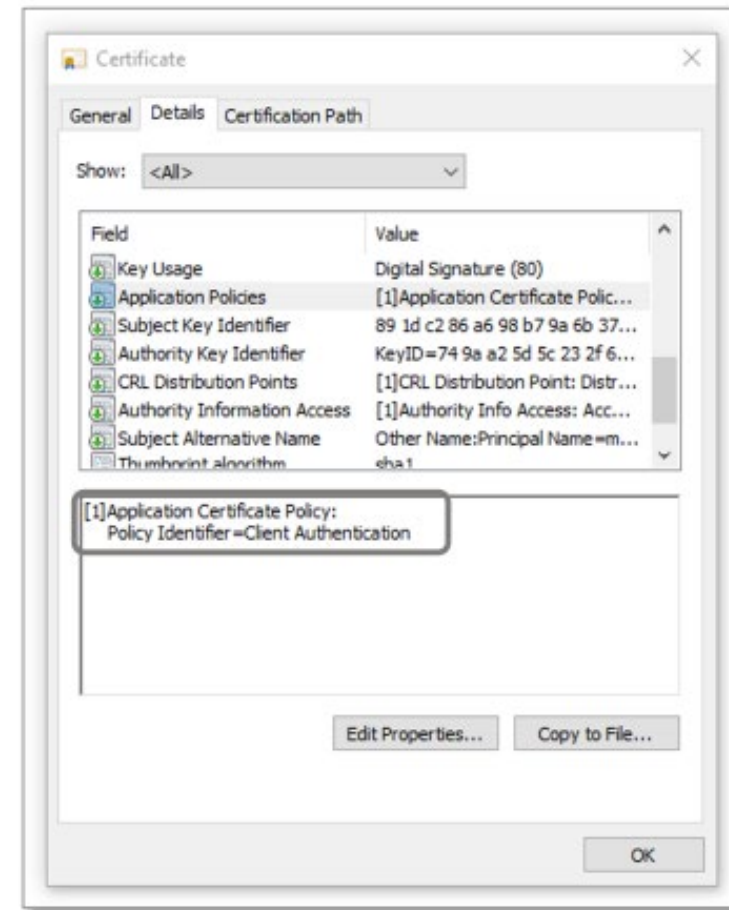


Certificate-Based Authentication (Non-Interactive)



Available only for web interface access

User Certificate



Configure a Certificate Profile

Device > Certificate Management > Certificate Profile > Add

Certificate Profile ?

Name: WebUI-Client-Cert

Username Field: None

User Domain:

CA Certificates

☐	NAME	DEFAULT OCSP URL	OCSP VERIFY CERTIFICATE	TEMPLATE NAME/OID
☐	WebUI-CA			

+ Add - Delete ↑ Move Up ↓ Move Down

Default OCSP URL (must start with http:// or https://)

☒ Use CRL CRL Receive Timeout (sec) 5

☒ Use OCSP OCSP Receive Timeout (sec) 5

OCSP takes precedence over CRL Certificate Status Timeout (sec) 10

Apply blocking actions (optional).

- ☒ Block session if certificate status is unknown
- ☒ Block session if certificate status cannot be retrieved within timeout
- ☒ Block session if the certificate was not issued to the authenticating device
- ☒ Block sessions with expired certificates

Used by the firewall to verify the client's user certificate

Configure Firewall Authentication Settings

Device > Setup > Management > Authentication Settings

Authentication Settings

Authentication Profile

None

Authentication profile to use for non-local admins. Only RADIUS, TACACS+ and SAML methods are supported.

Authentication Profile(Non-UI)

None

Authentication Profile to use for non-UI like CLI and API.

Certificate Profile

WebUI-Client-Cert

Idle Timeout (min)

60 (default)

API Key Lifetime (min)

0 (default)

API Keys Last Expired

Expire All API Keys

Failed Attempts

0

Lockout Time (min)

0

Max Session Count (number)

0

Max Session Time (min)

0

OK

Cancel

Used only for access through web interface, not CLI

Enables the firewall to verify client certificates using the Certificate Profile

Create an Administrator Account for Non-Interactive Login

Device > Administrators > Add

Administrator

Name

☒ Use only client certificate authentication (Web)

☐ Use Public Key Authentication (SSH)

Administrator Type ☐ Dynamic ☒ Role Based

Profile

- Selection of the check box configures the firewall to perform certificate-based authentication:
 - Authenticates access only to the firewall web interface, not to the CLI
- No longer prompted for an Authentication Profile
- Still must authorize user actions by specifying an Admin Role Profile



Discussion

- What are some use cases as to when you would use:
 - Local Authentication
 - XML Config File
 - Local Database
 - Remote Authentication
 - LDAP
 - RADIUS
 - Kerberos
 - TACACS +
 - Non-Interactive Authentication
 - Certificates

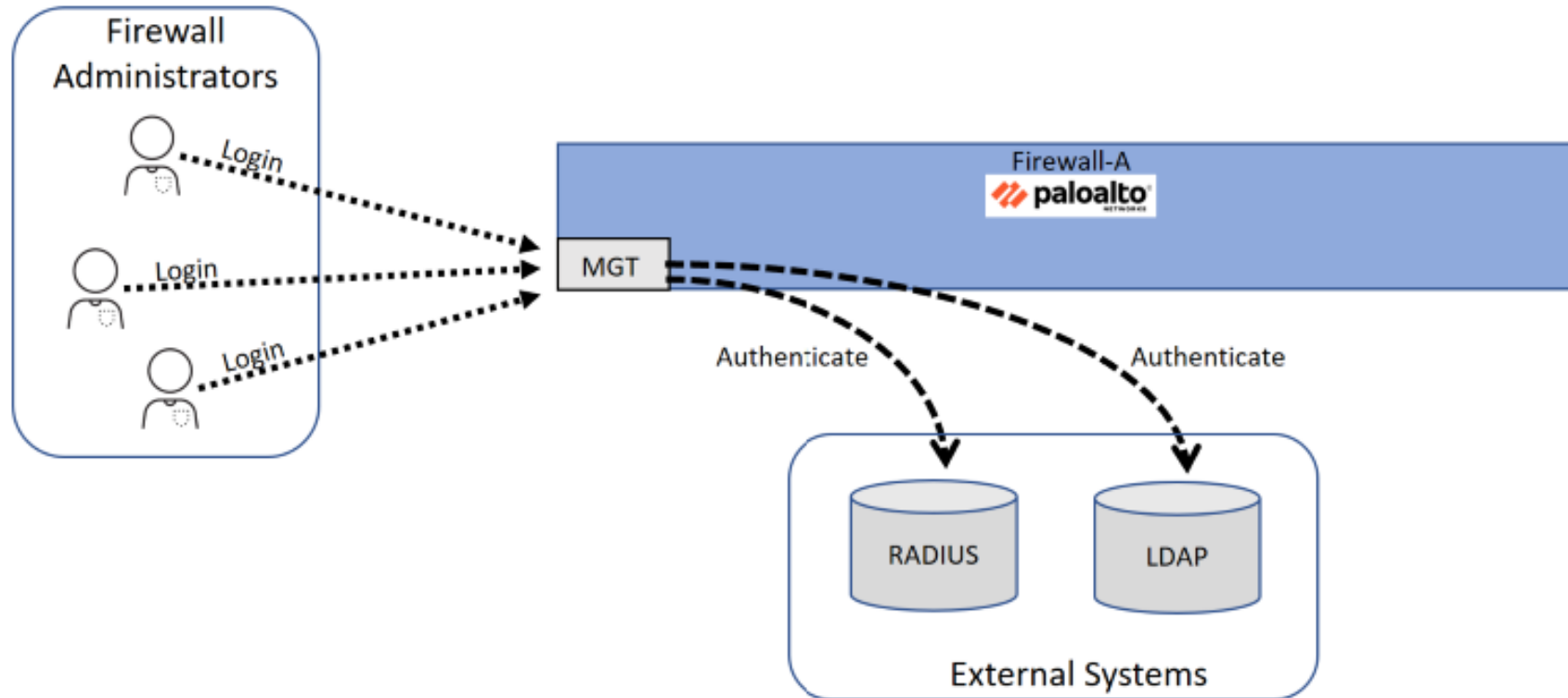
Module Summary

Now that you have completed this module, you should be able to:

- Describe the firewall authentication and authorization process and firewall components
- Create a local firewall administrator account
- Create a non-local firewall administrator account
- Create a firewall account that supports non-interactive login



Unit 4 Lab: Overview



Unit 4 Lab: Managing Firewall Administrator Accounts

- Load a baseline configuration
- Create a local firewall administrator account
- Configure an LDAP Server Profile
- Configure a RADIUS Server Profile
- Configure an LDAP Authentication Profile
- Configure a RADIUS Authentication Profile
- Configure an Authentication Sequence
- Create non-local firewall administrator accounts

End Content

Unit 4 Homework

- Always check Blackboard for assignments and when they are due.
- Unit 4 Lab: Managing Firewall Administrator Accounts
- Unit 4 Quiz